TRÍADE // PRODUTO & TECH EXEMPLOS

TASK-001: Implementação de Autenticação Segura JWT com Refresh Token e Rotação

CATEGORIA	RESPONSÁVEL	DATA / ATUALIZAÇÃO	STATUS
exemplos	Victor Rubinec	2026-10-14	Concluído

MÓDULO SEGURANÇA STATUS: CONCLUÍDO PRIORIDADE: ALTA

Visão Geral & Contexto

Esta tarefa visa substituir o modelo anterior de autenticação baseada em sessão por um mecanismo robusto e escalável de **Access Tokens JWT (vida curta de 15 min)** e **Refresh Tokens opacos rotativos (vida de 7 dias)**, armazenados em cookies HTTP-Only com proteção contra CSRF e XSS.

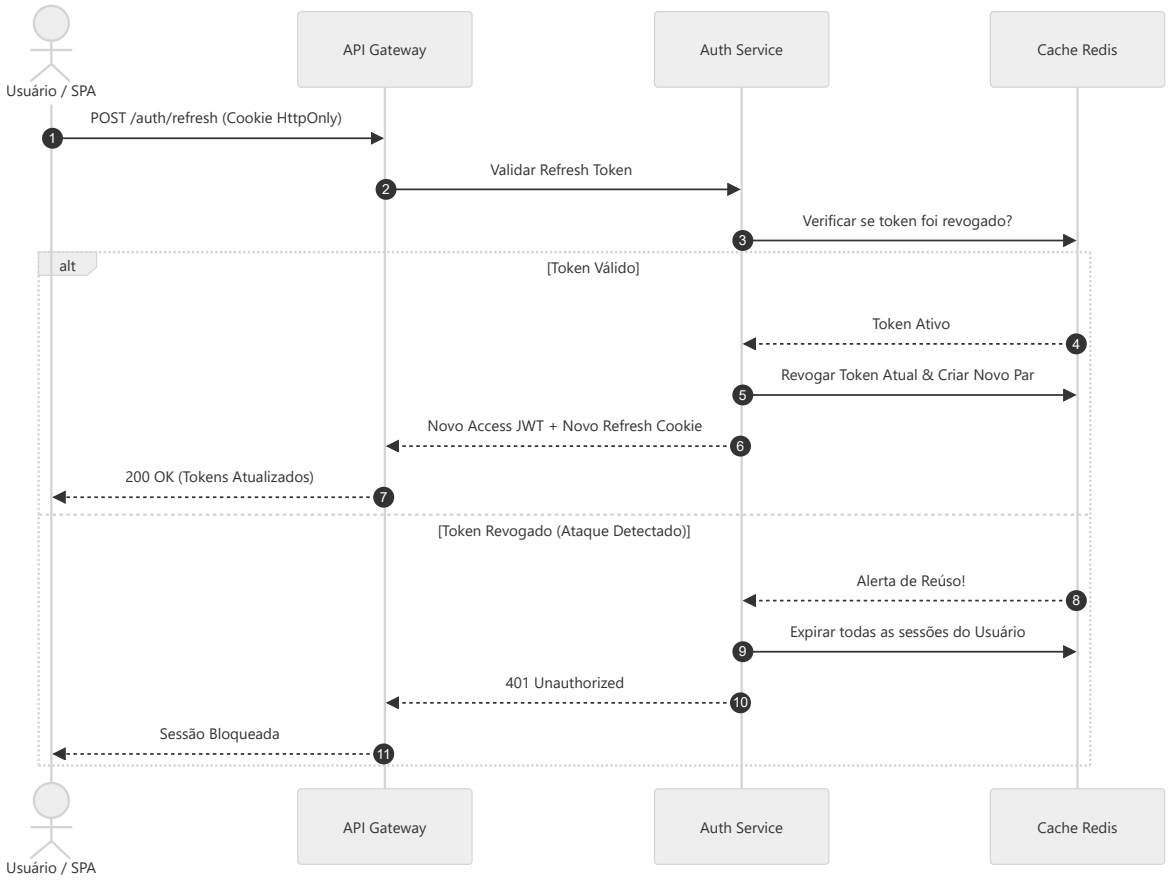
- **Responsável**: Engenheiro de Software
- **Complexidade**: Média (Segurança Crítica)
- **Status de Homologação**: 100% dos testes unitários e de integração aprovados.

---

1. Parecer Técnico & Análise de Segurança

> **Padrão OWASP Implementado**
> Adotamos a rotação obrigatória de refresh token: cada requisição de renovação invalida o refresh token anterior. Caso um token revogado seja reutilizado, todas as sessões do usuário são imediatamente invalidadas por suspeita de comprometimento.

1.1 Diagrama de Sequência da Rotação



2. Escopo Inicial (Imutável)

- [x] Criação de schema de dados para controle de tokens revogados.
- [x] Middleware de extração e validação de claims JWT via chave pública assimétrica (RS256).
- [x] Endpoints `/auth/login`, `/auth/refresh` e `/auth/logout`.
- [x] Testes automatizados cobrindo cenários de ataque de repetição (Replay Attack).

3. Linha do Tempo de Execução

2026-10-14 PRODUÇÃO

Deploy em Produção & Testes de Carga

Validação com 2.000 requisições concorrentes sem falhas de concorrência no Redis.

2026-10-12 HOMOLOGADO

Auditoria DevSecOps

Varredura SAST/DAST concluída sem apontamento de vulnerabilidades críticas.

2026-10-10 INICIADO

Início do Desenvolvimento

Definição dos contratos de API e escrita da suíte de testes TDD.

Assuntos Relacionados

- `01-ata-reuniao-arquitetura.mdx` — Ata de arquitetura que homologou a migração de autenticação.